Cinema Focus main website: remaining infrastructure hardening plan

Read-only inspection, 2026-10-31. Account 134283612566, region ap-south-1, stack cinemafocus-aws-prod. **Nothing was changed or deployed.** Covers F-02, F-18, F-09 and F-14. The store stack was not touched.

1. F-02: deployment identity validation

Check	Result
Identity	IAM user cinemafocus-aws (not root), account 134283612566, policy AdministratorAccess (full access), no MFA device, no groups.
Read-only vs deploy	Not read-only. Under this user, Stage 1, 2 and 3 deployments each completed (CloudFormation UPDATE_COMPLETE), as did DynamoDB create-backup, Cognito/Lambda/API Gateway/CloudFront reads and serverless package. Deployment permissions are proven for this stack.
Not yet proven	Store CDK deployments, Vercel or CI jobs, and the backup-aws.sh / restore-aws.sh scripts (they do not reference a profile, so they use whatever the shell exports).
Root keys	Two ACTIVE root keys. Key ...WXYI was last used 2026-10-31 by the AWS CLI on this Mac (profile 'store'). Key ...GKCS has never been used. Root MFA is enabled on the account.
IAM user keys	Two keys (the maximum). ...M2GI last used 2026-10-28 (S3); ...B2FC last used 2026-10-31 (DynamoDB, this audit). CloudTrail also shows STS AssumeRole calls from a JS SDK, which looks like a CDK deployment. If that is the store's CDK, the IAM user is shared with the store workflow.

Root key deactivation checklist (nothing executed)

Step	Action	Check / recovery
1	Find every consumer of root key ...WXYI: the 'store' profile in ~/.aws, shell exports, scripts, Vercel/CI secrets, the store's CDK deploys.	CloudTrail by AccessKeyId for the last 90 days; look for anything other than aws-cli on this Mac.
2	Point the 'store' profile at cinemafocus-aws (or switch scripts to AWS_PROFILE=cinemafocus-aws).	aws sts get-caller-identity must show user/cinemafocus-aws.
3	Run a full normal week of work (main site and store) on the IAM user.	Watch CloudTrail for AccessDenied errors from the user.
4	Deactivate the unused root key ...GKCS first (aws iam update-access-key --status Inactive). Do this yourself.	Recovery: set it back to Active. Root console sign-in with MFA is the fallback.
5	After 7 days with no issues, deactivate ...WXYI. Wait another 30 days.	Recovery: reactivate from the root console. Do not delete yet.
6	Delete both root keys. Keep root MFA. Do not create new root keys.	Not reversible; only after step 5 is clean.
7	Then reduce cinemafocus-aws from AdministratorAccess to a scoped policy, enable MFA, and rotate its keys (this chat's secret first).	Delete one key, create a new one, update consumers, delete the old.

2. F-18: Node.js 22 compatibility report

Item	Finding
Functions	39 Lambda functions, all handlers in infra/handlers, runtime nodejs20.x, 1024 MB, 6 s timeout, x86_64.
Dependencies	@aws-sdk/client-dynamodb, lib-dynamodb, client-s3, s3-request-presigner, client-cognito-identity-provider (3.1131.x, bundled in the package) and aws-jwt-verify 4.0.1.
Layers	None.
Native modules	None (no .node or binding.gyp files in node_modules). No engines field requires a version above 20.
Build config	No bundler or plugins. Serverless Framework v3 packages the whole infra folder (about 4.9 MB per function). The 'serverless doctor' notice reports one deprecation (the v3 framework itself).
Compatibility tests	All 49 tests pass under Node 22.23 (and Node 24). serverless package with runtime nodejs22.x succeeds: 39 functions, runtime nodejs22.x, memory and timeout unchanged.
Not tested	A live invocation on the nodejs22.x runtime. That only happens at deploy.

Migration plan

1) Change `provider.runtime` to nodejs22.x in one commit (one line). 2) Take no new DynamoDB backup (PITR is on). 3) Deploy. 4) Smoke test: public reads, admin login, one content save, one image upload, contact form. **Rollback:** set the runtime back to nodejs20.x and redeploy, unless AWS has already blocked updates to nodejs20.x (check the Lambda console before relying on this). **Risk:** low. Same SDK, no native code. Do the F-09 role change as a separate deployment so a failure is easy to attribute.

3. F-09: Lambda IAM role grouping matrix

Derived from the handler code (each function's actual DynamoDB, Cognito and S3 calls). Today all 39 functions share one role with all 9 tables (read/write/delete/batch), S3 Put/Get/Delete on the images bucket, and 5 Cognito actions. S3 Get and Delete and the DynamoDB Batch actions are never used by any handler.

Role	Functions (count)	Allowed actions and resources
cf-public-read	getProducts, getProduct, getCategories, getNewLaunches, getPressReleases, getPressRelease, getProjects, getSiteSettings (8)	dynamodb GetItem, Query, Scan on Products (+index), Categories, NewLaunches, PressReleases (+index), Projects, SiteSettings
cf-public-write	createMessage, incrementStat (2)	PutItem on Messages; UpdateItem on Stats
cf-auth-session	authLogin, authRefresh (2)	cognito-idp InitiateAuth on the main pool; UpdateItem on Stats (rate-limit counters)
cf-admin-content	create/update/delete for Products, Categories, NewLaunches, PressReleases, Projects (15); updateSiteSettings; getMessages, updateMessage, deleteMessage; getStats (20)	PutItem, UpdateItem, DeleteItem, GetItem, Scan, Query on those 6 content tables plus Messages; GetItem on Stats; GetItem on Products (reference check); Scan and UpdateItem on NewLaunches (product delete)
cf-admin-users	createUser, getUsers, getUser, updateUser, deleteUser, authChangePassword (6)	GetItem, PutItem, UpdateItem, DeleteItem, Scan on Users; cognito-idp AdminCreateUser, AdminDeleteUser, AdminSetUserPassword, InitiateAuth on the main pool
cf-admin-upload	getUploadUrl (1)	s3 PutObject on cinemafocus-images/* only

Every role also gets logs:CreateLogStream and logs:PutLogEvents on /aws/lambda/cinemafocus-aws-prod* (the log groups already exist in the stack, so CreateLogGroup is dropped). No role mentions the store table, the store bucket, the store pool or the store API, so no function gains store access; the existing template test already fails if any store ARN appears. An optional explicit Deny on the store ARNs adds a second layer but is not required.

Incremental migration with rollback

Phase	Change	Rollback
A	Add the 6 IAM Role resources (nothing uses them yet). Deploy.	Remove them. No effect on traffic.
B	Set role: on the 8 public-read functions. Deploy. Smoke test the public site.	Delete those role: lines and redeploy; they fall back to the shared role.
C	Switch public-write and auth-session (4 functions). Test the contact form and admin login.	Same.
D	Switch cf-admin-content (20). Save one item of each content type.	Same.
E	Switch cf-admin-users and cf-admin-upload (7). Create/edit a test user, upload an image.	Same.
F	After a clean week, remove the shared provider-level role statements. This deletes the old shared role, a production resource, so it needs your separate approval.	Re-add the statements and redeploy.

Implementation uses Serverless v3's native per-function `role:` pointing at Resources entries, with no new plugin. Phases B to E can be one deploy each; do not batch them.

4. F-14: CloudFront TLS upgrade plan

Item	Current state
Distribution	E2ET6E6X3C69LN, domain d2x0o69dm3vdcd.cloudfront.net, no aliases, default CloudFront certificate, viewer minimum protocol TLSv1, HTTP/1.1 only, PriceClass_All, no WAF, https-only viewer policy, OAC to the private images bucket, security-headers policy attached (Stage 3).
ACM certificates	None, in us-east-1 or ap-south-1.
DNS	cinemafocus.in is served by GoDaddy name servers (domaincontrol.com), not Route 53.
Stored URLs	DynamoDB records hold full URLs on d2x0o69dm3vdcd.cloudfront.net: Categories 13, Projects 11, PressReleases 2 (image_url), plus the Products images lists.

Requirements for a stronger minimum TLS policy

CloudFront only applies a minimum protocol version (such as TLSv1.2_2021) to a distribution that uses **a custom domain name and your own ACM certificate**. With the default *.cloudfront.net certificate the policy is fixed at TLSv1 and cannot be changed. So the upgrade needs: (1) a CDN hostname you control, for example cdn.cinemafocus.in; (2) an ACM certificate for it created in **us-east-1**, validated by a DNS CNAME; (3) a CNAME for the hostname pointing at the distribution. Steps 2 and 3 are DNS changes at GoDaddy, which I will not do without your approval.

Deployment plan (nothing executed)

Step	Action	Who
1	Choose the hostname (cdn.cinemafocus.in suggested).	You
2	Request the ACM certificate in us-east-1 (free) with DNS validation.	Me, after approval
3	Add the validation CNAME at GoDaddy. Wait for status ISSUED.	You
4	Update the distribution: Aliases, ViewerCertificate {AcmCertificateArn, SslSupportMethod: sni-only, MinimumProtocolVersion: TLSv1.2_2021}, HttpVersion http2and3, Compress on. A few minutes to propagate; the default domain keeps working throughout.	Me, after approval
5	Add the CNAME cdn -> d2x0o69dm3vdcd.cloudfront.net at GoDaddy.	You
6	Change CDN_DOMAIN (serverless.yml) and NEXT_PUBLIC_CDN_DOMAIN (Vercel and .env) to the new hostname. Allow both hosts in next.config.mjs remotePatterns so old and new URLs render. Redeploy both sides.	Me and you
7	Optional later: rewrite stored URLs to the new hostname. Not needed; the old domain still serves them (only on the old TLSv1 policy).	Optional

Rollback: remove the alias and ViewerCertificate block and redeploy; the distribution returns to the default certificate. Switch CDN_DOMAIN back. **Cost:** ACM is free, CloudFront pricing is unchanged. **Risks:** the certificate must be ISSUED before step 4 or the update fails; an alias already used by another distribution blocks it. WAF is separate (about USD 5 per month plus rules) and not recommended until abuse appears.

5. Risk summary and exact proposed changes

Task	Proposed change	Replacement or deletion?	Store impact	Needs approval for
F-02	Move profile 'store' to cinemafocus-aws; deactivate root keys in stages	Root keys deactivated, later deleted	Possibly: check the store CDK uses the IAM user	Each deactivation (you do it)
F-18	provider.runtime nodejs20.x -> nodejs22.x	No (functions updated in place)	None	Deployment

Task	Proposed change	Replacement or deletion?	Store impact	Needs approval for
F-09	6 Role resources, role: on each function, then remove shared role statements	Phase F deletes the old shared role	None (no store ARNs)	Each phase; phase F separately
F-14	Custom hostname, ACM cert, alias and TLSv1.2_2021 on the distribution	No	None	Hostname, DNS records, deployment

Suggested order: F-18 first (one line), then F-09 phases A-E, then F-14 once you pick the hostname, with F-02 running in parallel on your side. Rotate the cinemafocus-aws access key that was pasted into the chat before finishing.